

Security Review and Remediation Report

BharatOne retailer platform - mybharatone.com

Report date	7 August 2026	Version	1.1 - supersedes 1.0
Platform	mybharatone.com	Classification	Confidential
Prepared by	BharatOne engineering	Review type	Internal - not an independent audit

1. Summary

Concerns were raised about the security of the BharatOne platform. Those concerns were well founded. A review carried out on 6 and 7 August 2026 identified **twenty issues**: two critical, five high, nine medium and four low.

Eighteen are closed. Each fix was verified by measurement against the live system rather than by reading the code. The two that remain are low and medium severity and both require an action outside the codebase; they are listed in section 5 with four operational tasks that are also outstanding.

Note on the count. Version 1.0 of this report listed sixteen findings. Four more were found afterwards because testing continued, and three of those were in areas the first pass had reasoned about rather than measured. The most significant is finding 19: a set of server functions that any signed-in user could call, including one that returned the company account balance. Version 1.0 stated that a retailer could not obtain staff-level access. That statement was wrong and is corrected here.

No evidence of exploitation has been found for any issue, and no data loss has been identified.

Severity	Found	Closed	Open
Critical	2	2	0
High	5	5	0
Medium	9	8	1
Low	4	3	1
Total	20	18	2

2. Scope and method

The review covered the public website, all twelve portals, the PostgreSQL database and its row-level security policies, object storage, all thirty-four server-side functions, the front-end code and the production dependency tree.

Findings were established by **impersonating each class of user against the live database** and recording what they could actually reach: an anonymous visitor, a retailer, each staff role, and a staff member holding a valid password who had not completed two-factor authentication. Every remediation was re-tested the same way. Where a change risked locking users out, it was rehearsed inside a transaction that was rolled back, and that rehearsal output is quoted in the migration which applied it.

This was an internal review, performed by the party that built the platform. Section 7 addresses that limitation, which findings 17 to 20 illustrate directly.

3. Findings

#	Finding	Sev.	Evidence: before to after	Status
1	Identity documents in object storage readable without authentication	Critical	2,429 files readable by anyone to 0	Closed
2	Unauthenticated email endpoints permitting mail from the BharatOne domain to any recipient	Critical	2 endpoints open to the internet to staff only	Closed
3	Privileged database functions callable without authentication	High	282 anonymous-callable to 26	Closed
4	Two-factor authentication enforced in the browser only	High	235 registrations and 8 wallets readable without a code to 0	Closed
5	Configuration table readable by the public, including a password hash	High	28 of 28 rows public to 7	Closed
17	No protection against password guessing	High	Unlimited attempts to 5 per account, 40 per address, per 15 min	Closed
19	Staff-only server functions callable by any signed-in user	High	Retailer read the company balance of Rs 994,978.76 to refused	Closed
6	Legacy account lookup returning personal data with no password check	Medium	725 accounts exposed to function removed	Closed
7	Username enumeration across legacy accounts	Medium	Unlimited to 20 per address per 10 minutes	Closed
8	Support attachment storage configured as public	Medium	Public bucket, 0 files present, to private	Closed
9	Internal planning board public behind a browser-side password	Medium	13 MB, 122 internal screenshots public to admin plus 2FA	Closed
10	Server-side proxy attaching a third-party API key with no caller check	Medium	Open to signed-in callers only	Closed
11	Notification endpoint usable as an unauthenticated mail relay	Medium	Any body accepted to one-time token required	Closed
12	Payment gateway configuration readable by the public	Medium	Readable by anyone to signed-in only	Closed
18	Cross-site scripting in the public chatbot	Medium	javascript: links executed to escaped, scheme allow-list	Closed
20	Vulnerable production dependencies	Medium	2 high, 2 low, all with fixes available	Open
13	Role-check function callable anonymously	Low	Anyone could test for administrators to refused	Closed
14	Account suspension control had no effect	Low	Suspended users still signed in to sessions ended	Closed
15	A settings screen displayed two-factor status not read from the account	Low	Showed enabled on an account with none to live status	Closed
16	Scheduled health scan triggerable by anyone	Low	Open to shared-token gate; deployment pending	Open

4. The findings added since version 1.0

4.1. Staff-only server functions callable by any signed-in user

Severity: High

What was found. 334 elevated-privilege server functions are executable by signed-in users. 228 verify the caller inside the function; 106 did not. Among those were the administrator, accountant and quality-control dashboards, the list of administrator email addresses, the internal project tracker, and the company account balance.

Why it mattered. Any retailer with a valid login could read company-wide financial figures, the KYC queue, and the identities of the people who administer the platform. Version 1.0 of this report stated that a retailer could not reach staff-level access; that was tested against database tables and five specific attacks, and did not cover these functions.

What was changed. A caller check was added inside each affected function, since all application users share one database role and permissions alone cannot separate a retailer from an accountant. The check admits staff, scheduled jobs and the platform's own server functions, and refuses everyone else in identical wording regardless of who asks.

Verification. Measured after the change: a retailer is refused by all eight functions tested, including the company balance. Administrator dashboards return their normal figures, operator screens work, and both scheduled jobs and server-to-server calls are unaffected. Functions without a caller check reduced from 106 to 86; the remainder are database triggers, which cannot be called directly, and the intentionally public registration and tracking endpoints.

4.2. No protection against password guessing

Severity: High

What was found. There was no limit on failed sign-in attempts, no account lockout, and no record of failures to build one on. Staff accounts are protected by mandatory two-factor authentication, but the 62 retailer accounts, which hold wallet balances, are protected by a password alone.

Why it mattered. 89 accounts is a small enough set to attempt common passwords against every one of them.

What was changed. Five failures within fifteen minutes now lock that identifier for fifteen minutes, with a separate ceiling of forty attempts per network address. An identifier that does not exist is refused in identical wording, so the lockout cannot be used to discover which accounts are real. All three thresholds are configuration, changeable without a release.

Verification. Verified: four failures allowed, the fifth refused with a wait time; a non-existent username behaves identically; an unrelated account is unaffected; a successful sign-in clears the counter. This control protects the platform's own sign-in forms. The equivalent limit for direct interface calls is a provider setting listed in section 5.

4.3. Cross-site scripting in the public chatbot

Severity: Medium

What was found. The chat window rendered message text as live HTML. The same renderer draws both sides of the conversation, so visitor input was returned as markup, and its link rule inserted the supplied address into a link without validation, so a javascript: address produced a working script link on the public marketing site.

Why it mattered. A crafted link shared with a visitor could run code in their browser in the context of the BharatOne site.

What was changed. Message text is now escaped before formatting is applied, and link addresses must be http, https, mailto, tel or a path on this site; anything else is shown as plain text.

Verification. The rest of the front end was swept for the same pattern. The two print-window builders already escaped every inserted value correctly, and the remaining raw-HTML uses are a fixed stylesheet string and a charting library inserting its own colour values.

4.4. Vulnerable production dependencies

Severity: Medium

What was found. Four third-party packages in the production dependency tree carry published vulnerabilities: two rated high (js-yaml, postcss) and two low (dompurify, esbuild).

Why it mattered. Of the four, only dompurify is delivered to end users' browsers, and it is rated low. The other three are build tooling and are not reachable by an attacker at runtime; they are a supply-chain concern rather than a live exposure.

What was changed. Fixes are published for all four. The update has not yet been applied.

Verification. This finding remains open and is listed in section 5.

5. Outstanding items

Listed rather than omitted. A report that conceals its gaps is worth nothing the moment a reader finds one.

Item	Sev.	Status and owner
Rotation of a source-control token and payment-partner API keys	High	Not started. BharatOne management. The largest remaining exposure: the credentials are valid and were handled during development.
Sign-in rate limits at the authentication provider	High	Not set. One configuration screen. Covers direct interface calls, which finding 17 does not.
Finding 20: dependency updates	Medium	Fixes published; update not yet applied. One command plus a redeployment.
Breached-password screening	Medium	Available, not enabled. A single provider setting.
Staff enrolment in two-factor authentication	Medium	Enforcement is live and verified for all 19 staff accounts. 1 of 19 enrolled. The protection does not exist for an individual until they enrol.
Finding 16: shared-token gate on the scheduled health scan	Low	Database side applied and live; function deployment pending. No data or financial exposure.
Backup retention and recovery testing	Medium	Daily backups, seven-day retention, no point-in-time recovery, and no restore has ever been tested. Recommended before the platform grows further.

6. How to verify these claims independently

Every statement in section 3 can be reproduced by a technical reviewer holding the public interface key, which is embedded in the website and requires no privileged access.

Claim	How to check it
Identity documents are no longer public	Request a known document path with the public key and no session. Expect a refusal.
The database is not open	Query registrations, profiles, wallets, transactions and support tickets with the public key and no session. Expect zero rows from each. Row-level security is enabled on every table without exception.
Staff functions are closed to ordinary users	Sign in as a retailer and call the administrator dashboard or company balance function. Expect 'Not authorised'.
Two-factor is enforced beyond the browser	Authenticate an enrolled staff account by password alone, without a code, and query registrations. Expect zero rows.
Password guessing is limited	Submit five wrong passwords for any account through the sign-in form. Expect a refusal with a wait time on the fifth.

7. Recommendation and limitations

This review was not independent. It was carried out by the party that built the platform. Findings 17 to 20 demonstrate the cost of that: each was found only because testing continued past the point where the system appeared sound, and finding 19 corrected a statement made confidently in version 1.0 of this report.

An independent penetration test is recommended, by a firm with no involvement in building the system. This document gives such a firm a starting point, not a conclusion. Where assurance is required for a commercial or regulatory purpose, an external report is the appropriate instrument and this is not a substitute for one.

Three areas remain unexamined and should not be read as covered: recovery from backup, which has never been tested; staff device security and phishing resistance, which is where most real incidents begin and which no code change addresses; and the platform's use of third-party and government programme branding, which is a question for qualified legal counsel and not a security matter.

Prepared 7 August 2026. Supersedes version 1.0 of the same date. Figures were measured against the production system on 6 and 7 August 2026 and are accurate as at that date.